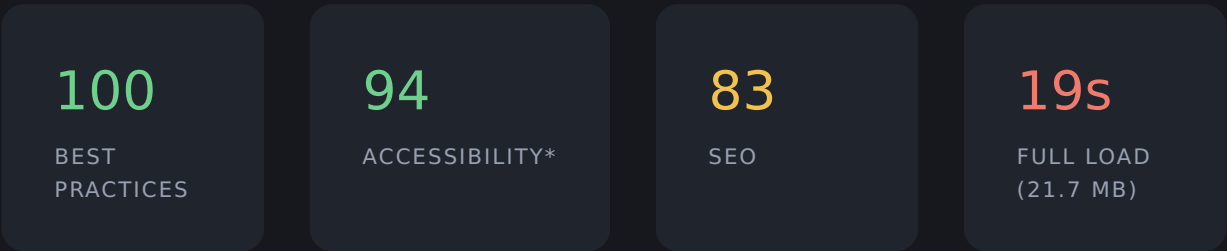


Soundings — Regional Creative Economy Maps

Full site mapping, functional validation, accessibility, security and performance audit, with an independent value estimate. Evidence captured live via instrumented Chrome (GPU sidecar) and analysed by a five-agent QE fleet.

Target: <https://soundings-23l.pages.dev/regions-map>

Audit date: 13 July 2026 · Data vintage on site: Companies House bulk register, July 2026



*Lighthouse figure; manual audit reveals keyboard/screen-reader gaps the automated score cannot see — see §6.

Prepared by the AgentBox QE fleet · collector + 5 specialist analysts · chrome-devtools-mcp / deck.gl-aware evidence pipeline

1 · Executive summary

Soundings is a genuinely well-crafted single-developer product with real engineering skill on show, one confirmed financial-exposure security issue, a serious accessibility gap, and a large untapped performance headroom. Every advertised function works; the map, search, drill-down and detail cards are correct and fast to interact with. The problems are not in what it does but in three engineering dimensions a buyer or funder would want closed before it carries commercial or public-sector weight.

The one thing to fix today: the embedded Google Maps API key (`AIza...OPEmI` , visible in page source) is not effectively restricted. The security analyst reproduced billable Geocoding and Static Maps responses from an anonymous, non-browser caller with a hostile `Referer` . This is a denial-of-wallet exposure: anyone can script requests billed to the owner's Google Cloud account. Fix is config-only (~15 min): restrict the key to the Maps JavaScript API on this domain and set a billing cap.

Dimension	Verdict	Headline
Functionality	Strong	All views, drill-down, search, filters, detail cards work; 0 JS errors
Engineering craft	7 / 10	deck.gl attribute transitions, van Wijk flight maths, compact tuple format, honest provenance UI — held back by zero test seams
Data correctness	1 defect	UK-tree England count (689,793) disagrees with drill-down (686,026) — un-deduplicated sum; author's own comment admits it
Security	Medium risk	1 confirmed billable-key exposure; XSS correctly defended; no PII; hardening headers missing
Accessibility	2 / 10	Every custom control (views, tree, filters, search) is mouse-only; keyboard/screen-reader users are locked out of core function
Performance	Headroom >10×	21.7 MB / 19 s first load is a design choice, not a limit; ~2 s achievable
Value	£45k-£180k	Central £85k-£110k as a transferable asset; capped by free/replicable data source

The recurring theme across the fleet's five analyses is that the capability is present but the policy or configuration defeats it: the lazy-loading machinery exists but the boot path force-loads everything; the escaping is correct but the security headers are absent; the data-dedup logic is correct at drill level but skipped for the top-level badge; the semantic HTML wins are there (`lang` , escaping, two real buttons) but every bespoke widget is an unlabelled `div` . Each is a small, well-scoped fix in the site's own idiom — none require a rewrite.

2 · What the product is

Soundings is an interactive, whole-UK map of 745,485 registered creative businesses, built from the Companies House bulk register (July 2026), geocoded to registered-office postcode centroids (postcodes.io, OGL), and classified through a proprietary "Soundings operational taxonomy" laid over UK SIC 2007. It presents a hierarchical region tree (UK → four nations → nine English regions → 60+ named sub-regions), three analytical views (Overview, Subsectors — the default, Size & scale), instant full-dataset company search, per-company detail cards with Companies House deep links, and subsector / size-tier / district filtering with fly-to-cluster shortcuts.

The footer positions this viewer as the multi-region sibling of a "North West flagship map" carrying an additional curated venues/festivals/institutions layer, with regions "added as asked" — i.e. a consultancy evidence-base product in the making, not yet a self-serve SaaS.

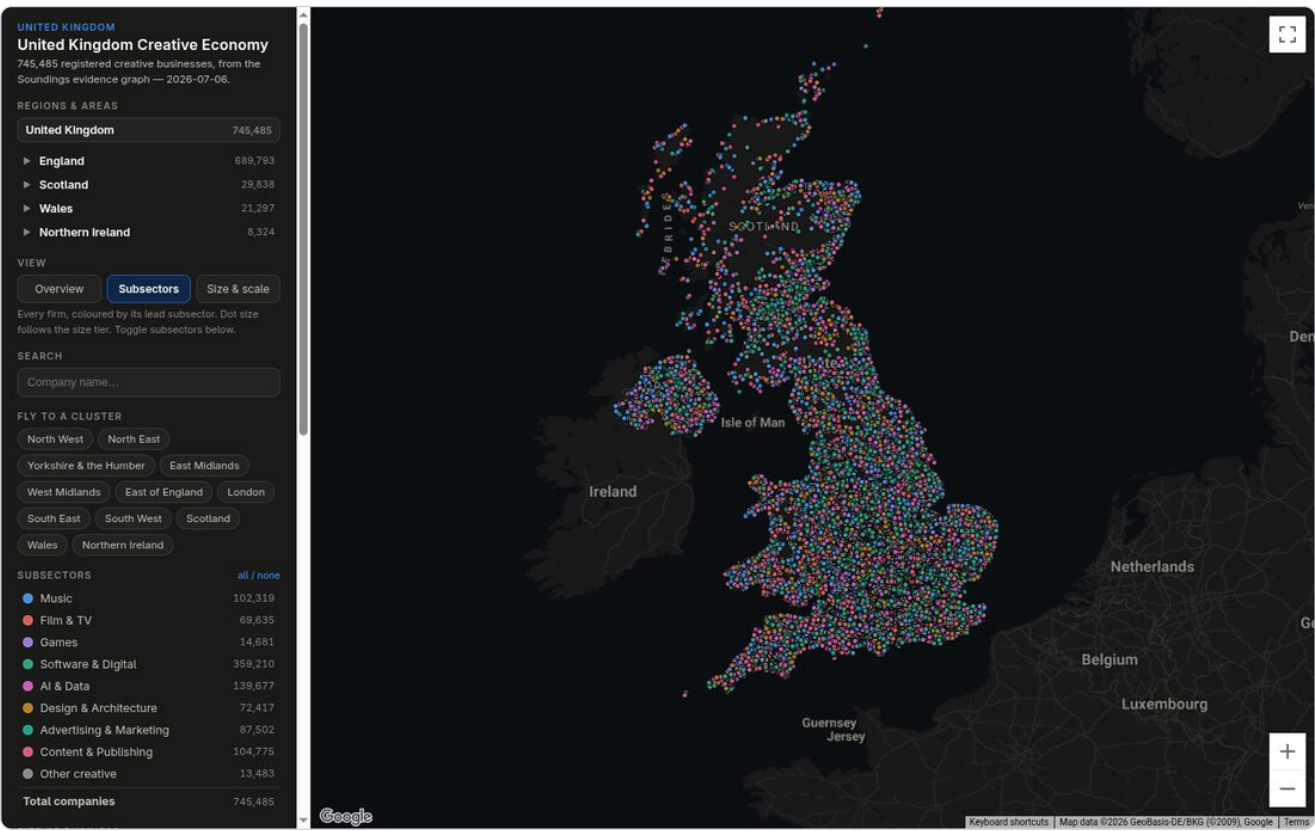


Fig 1 — Landing state: UK-level Subsectors view. Every firm is a dot coloured by lead subsector; sidebar carries the region tree, view switcher, search, fly-to clusters and filter groups.

2.1 · Site map & routes

Route	Status	Content
/regions-map	200	The application (64 KB single-file HTML, ~1,205 lines inline JS)
/	200	174-byte meta-refresh stub → regions-map.html
/data/regions_index.js	200	Region registry — 60 regions, per-region build dates & counts

/data/*_map_data.js (×67)	200	Per-region company tuples (21.4 MB total transfer)
/robots.txt, / sitemap.xml, /*	200 △	All unknown paths return the same 174-byte stub — no real 404, no crawler affordances

2.2 · Architecture

- Single-file vanilla-JS app — no framework, no build system. `deck.gl@9` (resolves 9.3.6) from unpkg CDN renders the point cloud as a WebGL overlay on a Google Maps vector basemap.
- Data as code: 67 static `data/*_map_data.js` files, each assigning a window global; companies are compact tuples `[name, lat, lng, [sectors], sizeTier, district, CHN0, year]`.
- Registry-driven regions: `regions_index.js` declares slug/file/count per region — adding a region is dropping a data file (the claim holds; see §8).
- Hosting: Cloudflare Pages (HTTP/2 + h3, edge-cached, NEL reporting on).
- Graceful key fallback: if the embedded Google Maps key fails, a hidden panel asks the user for their own key ("Load map").

3 · Measured performance

Metric	Value	Note
Total transfer, first load	21.7 MB	21.4 MB is region data (67 files)
Largest single asset	6.8 MB (compressed)	greater_london_map_data.js — 4.2 s alone
DOMContentLoaded	1.12 s	Shell is fast — sidebar & map frame appear early
load event	19.0 s	All 67 regions load eagerly at startup
Caching policy	max-age=0, must-revalidate	Multi-MB files revalidate on every visit; no fingerprinting, no immutable
JS console	0 errors	Only a Chrome WebGL perf warning (GPU stall on buffer mapping) under the 745k-point load

3.1 · Root cause of the 19-second load

The 19 s is not a bandwidth limit — on the datacentre link the 21.7 MB arrives in ~2–3 s. The cost is client-side, and it is a design decision. The boot path defaults to the whole-UK view, and `loadUK()` merges every region's full point set — 745,485 individual companies assembled from ~38 data files on the critical path, loaded serially at the top level. An idle prefetch loop then pulls the remaining ~29 files "just in case" (hence 67 files / 21.7 MB total vs the ~38 files / 18.6 MB the view strictly needs). The dominant delay is the JS engine parsing ~52 MB of decompressed JavaScript source (each data file is a giant array literal of 745k rows) plus a client-side merge-and-dedupe pass.

The irony the performance analyst highlights: at UK zoom, 745k dots overplot into an undifferentiated density cloud where no single point is legible — so the full-fidelity data buys nothing at that zoom. The per-region counts already exist in the 1.6 KB region index; only drill-down actually needs the point rows, and the lazy path for that already exists and works.

Brotli check (curl-verified): compression is already on (`content-encoding: br`) — but at Cloudflare's low dynamic quality. On London, the brotli body (7.006 MB) is actually 4.8% larger than gzip (6.683 MB), the signature of on-the-fly $q \approx 4$ compression. Build-time max-brotli (q11) would still shave ~15–20%.

3.2 · Optimisation plan and achievable end-state

Change	Effect	Impact
--------	--------	--------

(a) Lazy default view + index-driven totals — don't force-load every region at boot; draw a pre-binned ~50k-point overview, take totals from the index	Removes the 52 MB parse and UK merge from the critical path	21.7 MB → ~1.4 MB (~15×); does ~90% of the work
(b) Binary columnar format (typed arrays via fetch, not script injection)	<code>new Float32Array(buffer)</code> ≈ 0 ms vs seconds of JS parse	Parse seconds → ~100 ms; wire —15–20%
(c) Immutable caching + fingerprinted filenames	Kills ~38 conditional 304 round-trips per repeat visit (~4 s of pure latency, zero bytes)	Repeat visit ~4 s → ~0.3 s
(e) Viewport deck.gl windowing — stop keeping the full UK set GPU-resident after drill-in	Ends the "GPU stall ... mapping device local buffer" warnings	Smoother filter/ mode transitions

Scenario	Today	Achievable
First load, 4G (~10 Mbps)	~25 s	~2 s
First load, fast link	19 s	~1.5 s
Repeat visit	~4 s revalidation	~0.3 s
Initial transfer	21.7 MB	~1.4 MB
JS parsed on load	~52 MB	~1 MB binary

What is already good (keep): compact dictionary-encoded tuple rows, static Cloudflare-Pages/CDN hosting with low TTFB, a single persistent deck.gl layer set with opacity-crossfade view switching, and disciplined client-side caching (`parsedCache` , memoised visibility, idle-slot warm parsing, retina cap at 1.5×). The fix is to stop doing that work eagerly for all regions — not to remove the caches.

4 · Functional validation

Behaviour	Result	Evidence
Region tree drill-down (UK → England → North West)	PASS	H1/breadcrumb/counts update; map reframes (Figs 3–4)
View switcher (Overview / Subsectors / Size & scale)	PASS	Legend & description swap (Figs 1–2)
Fly-to-cluster, context-sensitive per level	PASS	London flight (Fig 5)
Search across 745k records	PASS	"aardman" → 9 group entities, instant (Fig 6)
Search-result click → fly + detail card + CH deep link	PASS	Aardman Animations, Bristol; correct sectors, size tier, 1986 (Fig 7)
Subsector filter toggle & restore	PASS	Music off → SHOWING 670,960; exact restore
Cross-view count consistency	FAIL	England: 689,793 (UK level) vs 686,026 (drilled) — §8 has the root cause
Mobile layout ≤ 500 px	FAIL	Fixed 280 px sidebar; map squeezed to 220 px (Fig 8)
Crawler/agent affordances (robots, sitemap, meta description, llms.txt)	FAIL	All absent; every path 200s with a stub

Data-consistency note. Toggling a single subsector removes fewer firms than the sidebar count for that subsector suggests (Music: –74,525 vs a stated 102,319) because firms carry multiple sector tags and the sidebar counts tag membership. Not a defect, but users reading the two numbers together will be confused; a one-line legend fix.

5 · Consolidated findings register

Consolidated across all five fleet analyses, ranked by priority. Severity is calibrated for a public, cookieless, no-auth static data product — not inflated.

#	Sev	Finding	Area	Fix effort
1	MED	Google Maps key not effectively restricted — anonymous callers get billable Geocoding + Static Maps (denial-of-wallet). Reproduced by probe.	Security	~15 min, config only
2	HIGH	Data inconsistency: England shows 689,793 at UK level vs 686,026 drilled — <code>updateNav()</code> sums region counts with no company-number dedup; drill path dedups. $\Delta = 3,767$ overlaps.	Correctness	Small — badge from deduped set
3	CRIT×4	Keyboard/screen-reader lockout: view switcher, region tree, filter chips and map data are all mouse-only <code>div / span</code> with no <code>role/tabindex</code> . A11y maturity 2/10.	Accessibility	1 shared helper + ~10 edits
4	MED	21.7 MB / 19 s first load — boot force-loads all 745k points; lazy machinery exists but is bypassed. ~2 s achievable.	Performance	Medium — change boot path
5	MED	No Content-Security-Policy; <code>deck.gl</code> loaded from <code>unpkg</code> via mutable <code>@9</code> tag with no SRI (supply-chain drift, full page privileges).	Security	Medium — <code>_headers</code> + <code>pin/self-host</code>
6	MOD	Mobile layout broken $\leq 500\text{px}$ — fixed 280px sidebar never collapses; map squeezed to ~110px on a real phone.	UX	Medium — responsive layout
7	MOD	SEO/crawler blind: no <code>robots.txt</code> , sitemap, meta description, <code>llms.txt</code> or OG cards; every path 200s with a 174-byte stub.	SEO	Small
8	MOD	Colour-contrast fail (4.37:1) on muted count text; no <code><main></code> landmark; H2 precedes H1.	Accessibility	Small — 1 token + 2 attrs
9	MOD	Unhandled promise rejection on a failed leaf data-load (<code>switchRegion</code> has no <code>.catch</code>) → dead click, no error UI.	Robustness	Small
10	LOW	Missing hardening headers (HSTS, X-Frame-Options, Permissions-Policy); API-key input is <code>type=password</code> (credential-manager confusion, not a leak); caching sends <code>max-age=0</code> on multi-MB files.	Security/ Perf	Small — <code>_headers</code>

Notable positive: the XSS surface is correctly defended — every data-derived value reaching `innerHTML` passes through a correct escaper, the Companies House deep link is safely attribute-encoded and carries `rel="noopener"` , and there is no PII beyond the public register. The security analyst rated the site LOW risk on everything except the billable-key exposure.

6 · Accessibility (WCAG 2.2 AA)

Accessibility maturity: 2 / 10. 4 critical · 6 serious · 4 moderate · 1 minor = 15 findings. The Lighthouse score of 94 is misleading: the auditor sees the bespoke widgets as inert text, so it cannot detect that they are inoperable by keyboard or screen reader.

The app gets the free wins — `<html lang="en">`, a title, correctly escaped output, and two real `<button>` elements — but every control it built itself is a `<div>` or `<span>` with an `onclick` and nothing else: no role, no tabindex, no keyboard handler. There are zero ARIA attributes, zero `<label>` elements, no live region, and no landmarks in the entire document. Keyboard-only and screen-reader users cannot switch views, drill the region tree, apply a filter, or read a company record.

Critical findings	WCAG 2.2	Why it matters
View-mode switcher is 3 mouse-only <code>div</code> s	2.1.1, 4.1.2	Users are locked into the default Subsectors view
Region tree (60+ rows) mouse-only, no tree/expand semantics	2.1.1, 4.1.2, 1.3.1	The app's primary navigation is unreachable without a mouse
Filter chips mouse-only; on/off state by opacity alone	2.1.1, 4.1.2, 1.4.1	Filtering 745k records is impossible for keyboard/SR users
Map canvas has no non-visual alternative; point data hover-only	1.1.1, 2.1.1	The core content exists only as pixels

The good news: the fix surface is small and idiomatic. The a11y analyst supplied a single ~15-line `actuate()` helper (adds role, tabindex and Enter/Space handling to any element) that, plus a focus-visible CSS block and a `.visually-hidden` utility, unblocks seven of the findings at once. The remaining items are a one-line contrast-token change (`--muted #898781 → #9a988f`), promoting `#map` to `<main>`, and adding one polite live region. No framework, no build step — every fix is a drop-in. Full remediation code with line references: [data/fleet/a11y-findings.md](#).

7 · Security posture

Overall risk: MEDIUM — driven solely by the billable-key exposure. 0 critical · 0 high · 3 medium · 4 low. Absent the key issue this is a LOW-risk site: no PII, no auth, no cookies, no backend, and a correctly-defended XSS surface.

7.1 · The confirmed exposure (reproduced by probe)

The source comment claims the Maps key is "referrer-restricted ... so it only works on this site's domains." The probes refute that. Both a Static Maps request and a Geocoding request returned HTTP 200 with real billable results when sent with no `Referer` and again with a hostile `Referer`: `https://evil.example.com/`.

Probe	Referer	Result
Static Maps API	none / evil.example.com	200, valid PNG tile served
Geocoding API	none / evil.example.com	200, "status":"OK", real results

Web-service APIs (Geocoding, Directions, Places) cannot be referrer-restricted at all — the Geocoding success proves they are enabled on this key with no effective restriction. An attacker scrapes the key from page source and scripts billable calls against the owner's account. Remediation (~15 min, config only): in Google Cloud Console, restrict the key's application to HTTP referrers on `soundings-23l.pages.dev/*`, restrict its APIs to the Maps JavaScript API only (explicitly disabling Geocoding/Static Maps/Directions/Places), and set a billing budget + quota cap. The app already degrades gracefully to a "map temporarily unavailable" panel, so a quota cap bounds the worst case cleanly.

7.2 · Other medium/low findings

- No CSP (medium) — the highest-leverage header, because it also bounds the blast radius of the third-party bundle and the exposed key. The analyst supplied a ready-to-ship CSP tuned for the exact Google-Maps + unpkg dependency set, deliverable via a Cloudflare Pages `_headers` file.
- Supply chain (medium) — `deck.gl` loads from `unpkg.com/deck.gl@9`, a mutable tag that 302-redirects to 9.3.6, running with full page privileges and no SRI. Fix: self-host a vendored pinned copy, or pin the exact version + add the SRI hash (both provided).
- Low: no HSTS, no X-Frame-Options/frame-ancestors, no Permissions-Policy; the `type=password` key input. All resolved in the same `_headers` file plus a one-attribute input change.

Positives confirmed: correct output escaping on all data sinks; `rel="noopener"` on the external link; `nosniff` and a sane referrer-policy already present; wildcard CORS is harmless-to-beneficial for an open dataset; no PII beyond the public Companies House register. Full detail incl. the CSP value and SRI hash: `data/fleet/security-findings.md`.

8 · Code quality & engineering assessment

Craft rating: 7 / 10. Skilled front-end work with a knowingly-shipped correctness inconsistency and zero test seams. Embodied engineering effort estimated at ~25 person-days (~10 viewer + ~15 data pipeline).

8.1 · What is genuinely good

- Sophisticated deck.gl choreography: one persistent layer set; mode/filter changes re-colour and re-size the same dots via GPU attribute transitions; view switches crossfade whole layer sets by opacity with cloned "ghost" layers — avoiding a buffer rebuild on the click frame. This is real deck.gl expertise.
- van Wijk–Nuij optimal zoom-pan flight path hand-implemented in web-mercator world coordinates (the maths behind Google Earth / MapLibre flights) — ~60 lines of non-trivial, correct algorithm rather than a naïve interpolation.
- Compact tuple data format with per-file sector/district dictionaries — the correct bandwidth decision for 745k rows (a JSON-of-objects format would roughly triple transfer size).
- Graceful degradation (a `MutationObserver` catches Google's quota/billing error and swaps in a calm panel) and intellectually honest provenance UI ("claimed, not verified", named sources, licences, per-region build dates).

8.2 · Root cause of the count discrepancy

The code reviewer traced it precisely. The UK-level England badge is computed in `updateNav()` (lines 838–843) as a naïve arithmetic sum of per-region index counts — mixing whole-region file counts for some nations with sums of child counts for the five "combine" regions — with no deduplication. That sum double-counts child files that overlap within a region (e.g. `north_devon` $\subset$ `devon`) and companies whose registered-office postcode straddles a nation boundary. The drill-down value comes from `mergePayloads()` (lines 538–554), which dedups on Companies House number. The 3,767-company delta is exactly those overlaps. Reconstructing the naïve sum against the shipped index reproduces 689,793 to the digit — and the author knew: a comment reads "overlapping lenses may double-count." The clean fix is to size every group badge from a deduplicated set of company numbers, eliminating the sum path.

8.3 · Weaknesses & embodied effort

Real weaknesses: zero testability (no modules, no exports, everything closes over live singletons and writes straight to the DOM — for a product whose whole value is counts being correct, this is the most consequential gap); an unhandled promise rejection on a failed leaf load; 60+ mutable window globals from the data layer; and the a11y gaps above. The "add a region = drop a data file" claim mostly holds — discovery is genuinely zero-touch — but correct hierarchical placement still needs one `NAV` array edit.

Component	Person-days
Viewer (deck.gl orchestration, flight maths, region tree, parsing/caching, panel/cards, CSS, perf tuning)	~10
Data pipeline (Companies House ingest, SIC→taxonomy mapping, postcode geocoding, size-tier classification, per-region dedup + file generation, cluster curation)	~15
Total embodied effort	~25 (range 22–29)

The SIC-2007 → "Soundings operational taxonomy" mapping is the single largest uncertainty and the most defensible IP; a thin lookup is cheap, a substantial curated asset pushes pipeline effort higher. Full analysis with line references: [data/fleet/code-review-findings.md](#) .

9 · Value estimate

Headline: £45,000 – £180,000 as a standalone transferable asset; most likely £85,000–£110,000. Confidence moderate — the floor is anchored by rebuild cost; the ceiling is capped by free-data replicability. Full analysis with citations: [data/fleet/value-estimate.md](#) .

9.1 · Three valuation lenses

Lens	Basis	Range	Central
A — Replacement / build cost	40–90 person-days × £600–900/day UK senior contractor	£24k – £81k	~£49k
B — Market comparables	Licence benchmarked to The Data City tiers, discounted 30–40% for narrower scope; per-region commission engine	£20k–£40k/yr recurring (capitalised £40k–£160k)	~£30k/yr
C — Strategic / IP asset	Taxonomy IP + reproducible pipeline + whole-UK coverage, sold as an asset	£60k – £250k	~£130k

9.2 · Strongest market comparables

- The Data City (closest functional analogue — real-time sector classification of the UK register): published pricing Solo £10k/yr, Team £22k/yr, Department £35k/yr; bespoke sector builds £20–25k/yr; cluster-analysis projects from £20k. Soundings is a narrower, static, single-vertical product — hence the 30–40% discount applied.
- Beauhurst (premium UK company-data platform): custom quotes, widely reported at £10k+/seat/yr.
- Commission market context: regional creative-economy mapping commissions typically run £20k–£80k per region; The Audience Agency's Tees Valley mapping underpinned a £20m investment programme, and the £150m Creative Places Growth Fund (2025) gave six combined authorities £25m each — real buyer budgets exist for exactly this evidence product.

9.3 · What moves the number

- Biggest uplift: attach modelled revenue/employment estimates (closes the core gap vs The Data City/Beauhurst; est. +50–100% strategic value).
- Fastest path above the ceiling: one anchor client at £20–35k/yr capitalises to £100k–£300k on a 3–4× ARR multiple.
- Structural cap: the data source (Companies House + postcodes.io) is free and replicable — the durable moat is only the taxonomy and time-to-market. Registered-office-vs-trading-address (honestly labelled "claimed, not verified" in-product) limits hard economic-impact claims.

- Bundle effect: selling with the NW flagship's curated layer, brand and client book reaches toward the ~£250k strategic top; the viewer alone sits near the floor.

10 · Screenshot evidence

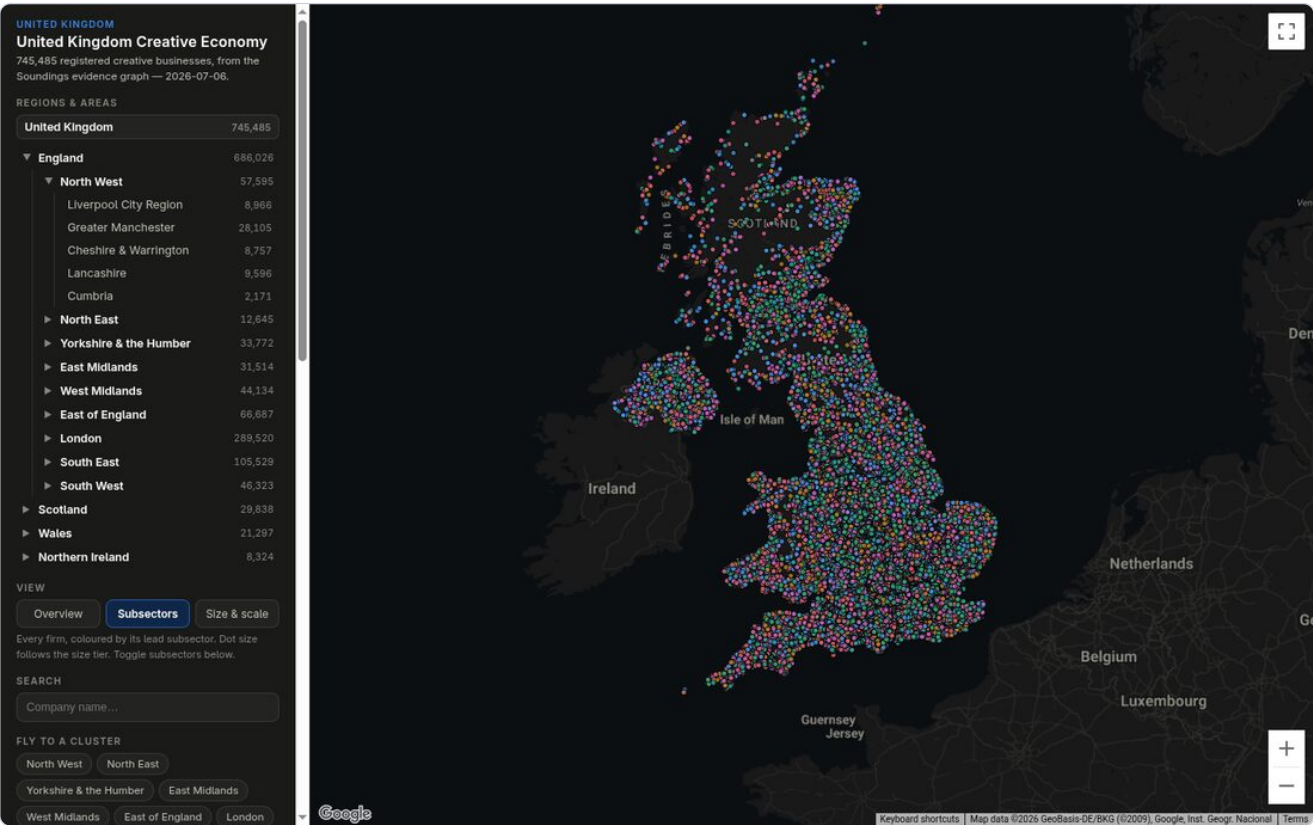


Fig 2 — Subsectors view with region tree expanded (England → North West). Note tree shows England 686,026 here vs 689,793 in Fig 1 — the count-consistency defect.

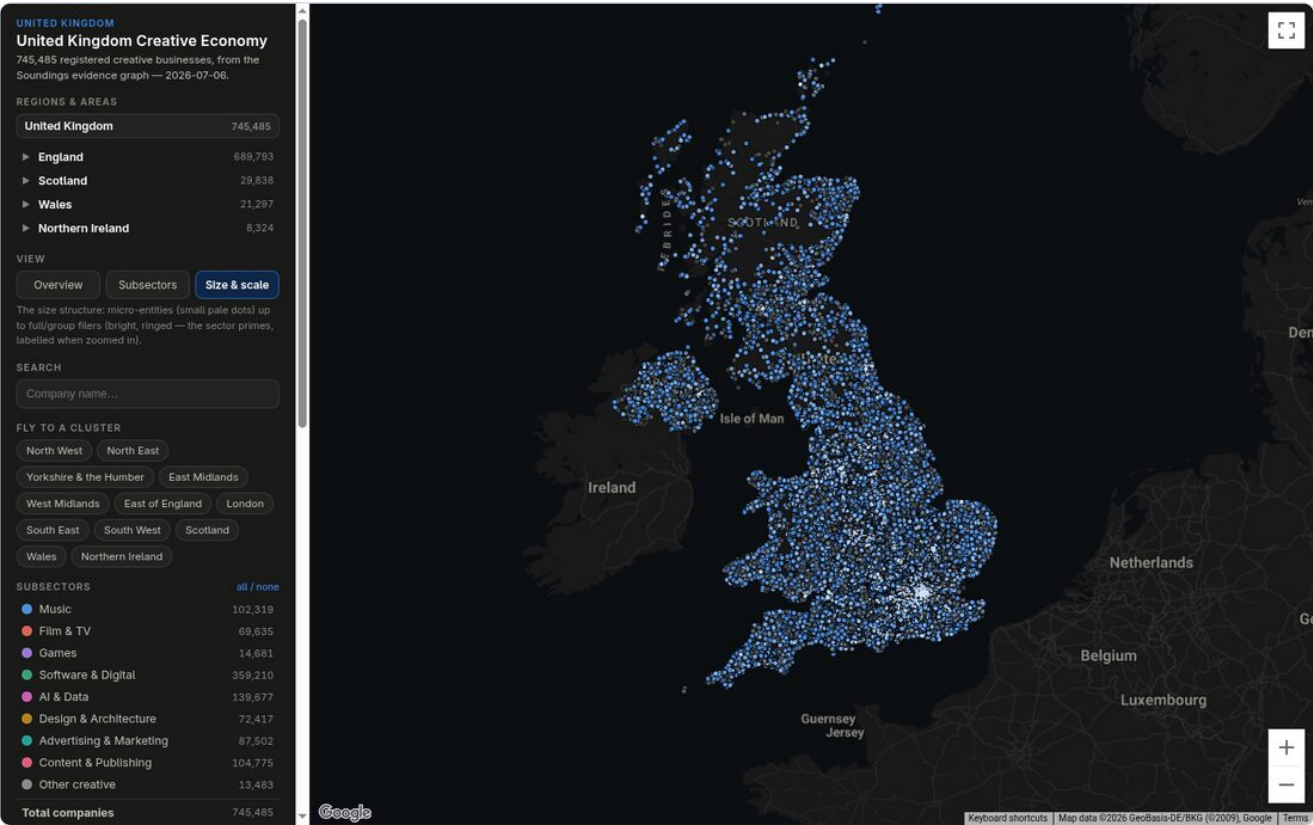


Fig 3 — Size & scale view: size-tier legend (sector primes / small / micro / dormant / not-yet-filed).

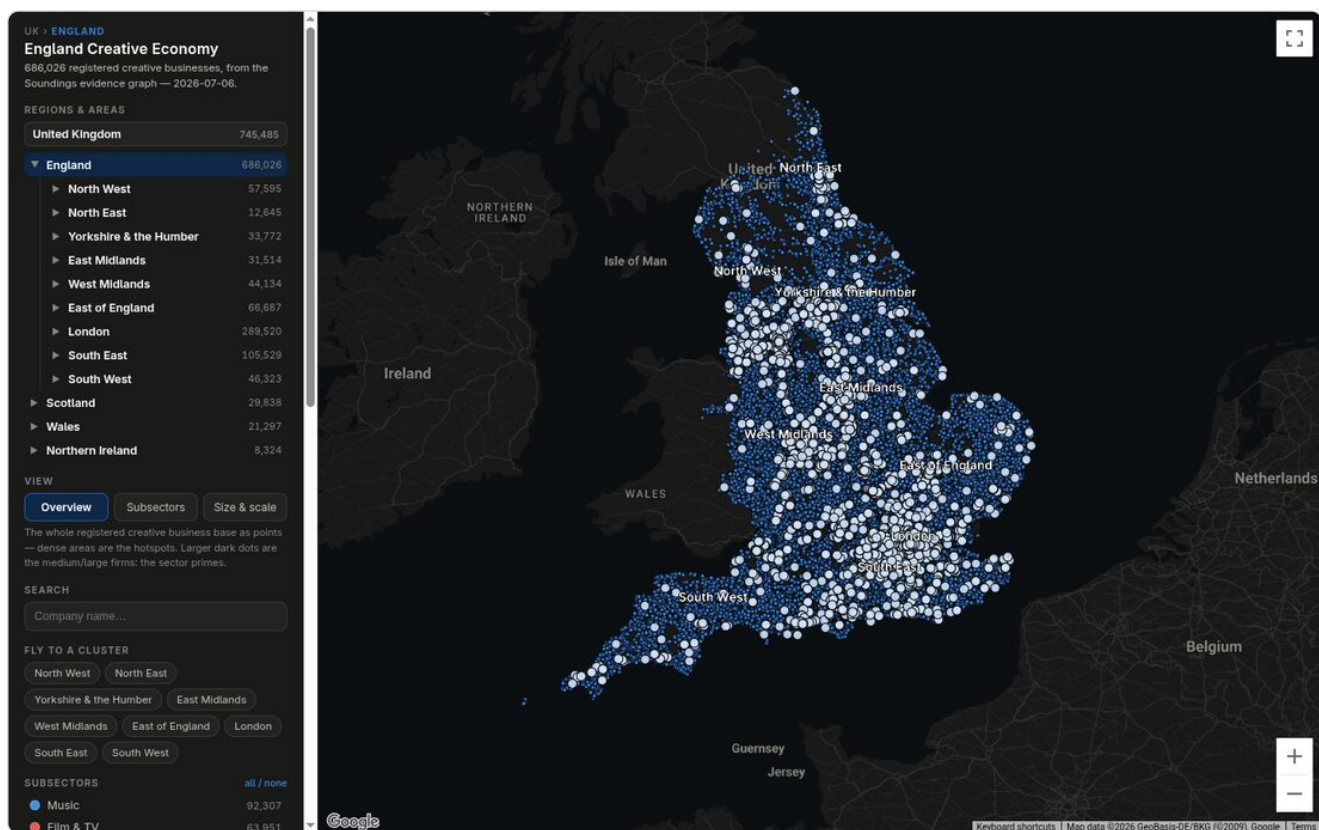


Fig 4 — England drill-down, Overview mode: nine English regions in tree and district panel.



Fig 5 — Fly-to London: 289,520 firms; densest cluster in the dataset.



Fig 6 — Live search over the full register: the Aardman corporate family (9 entities).

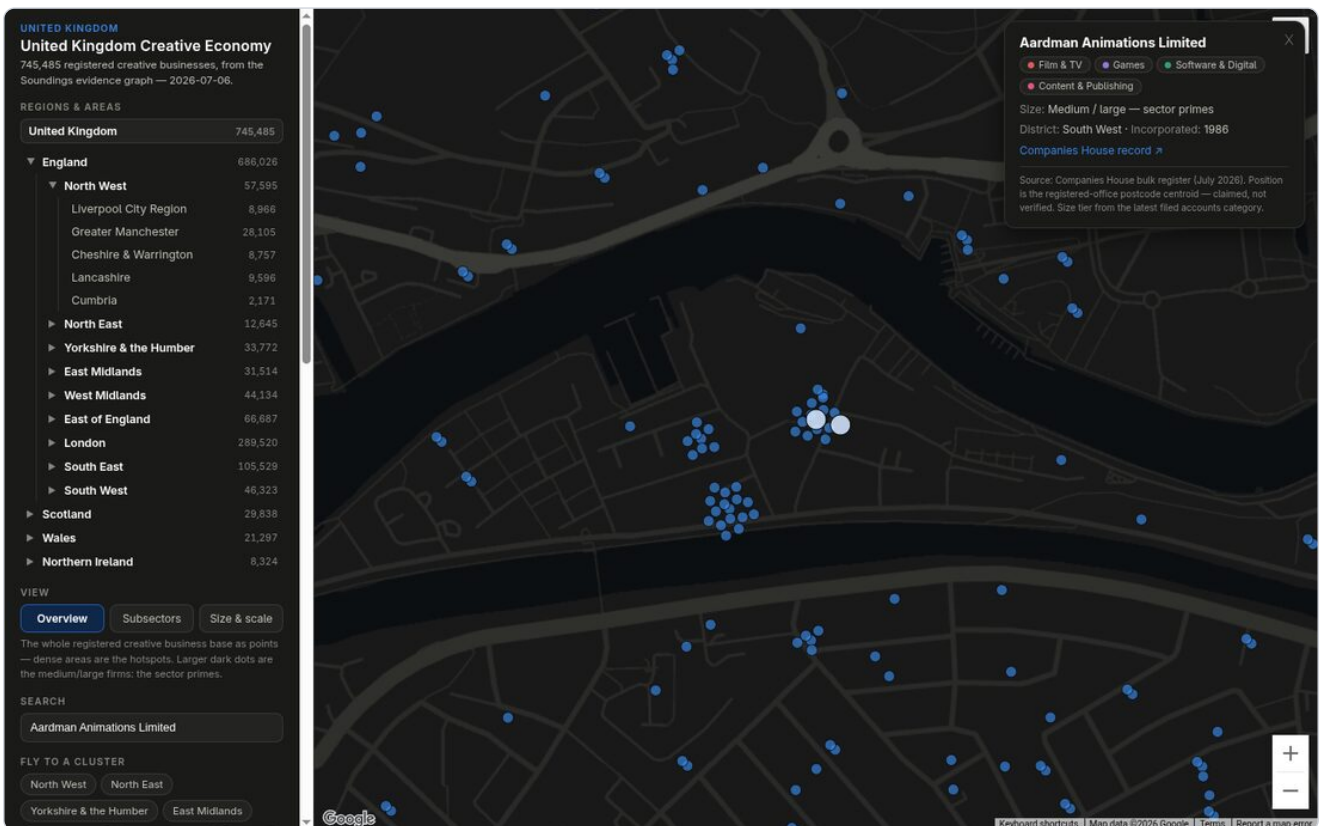


Fig 7 — Company detail card: sector chips, size tier, district, incorporation year, Companies House deep link, and honest provenance text ("claimed, not verified").

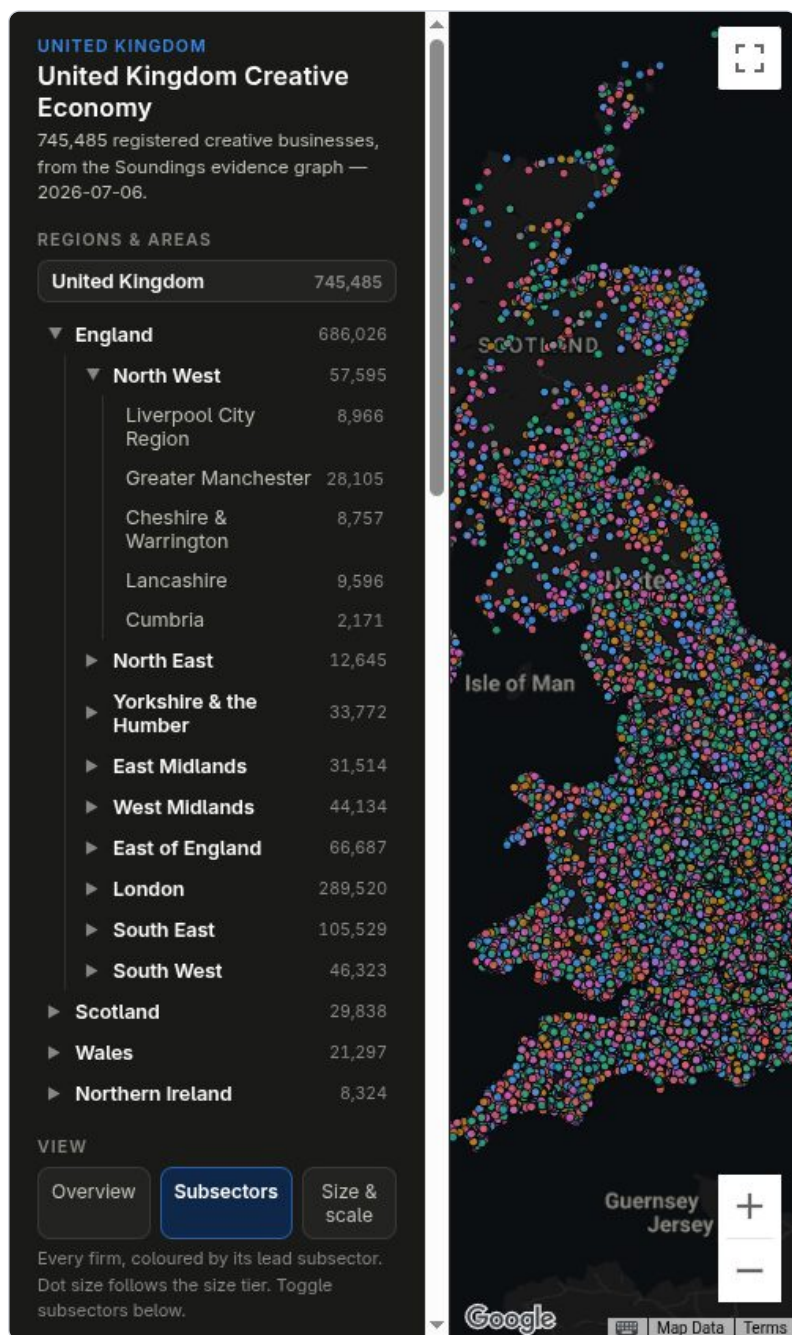


Fig 8 — Mobile squeeze: fixed 280 px sidebar leaves the map ~220 px at a 500 px window (~110 px on a real 390 px phone).

11 · Method & evidence inventory

Evidence was captured live on 13 July 2026 with an instrumented Chrome (chrome-devtools-mcp on a GPU sidecar): accessibility-tree snapshots, viewport screenshots, Resource Timing measurements, console and network logs, Lighthouse (navigation mode, desktop), plus read-only curl probes for headers and route behaviour. A five-agent QE fleet (accessibility, security, performance, code review, market research) then analysed the captured artifacts in parallel; the collector-then-analysts topology avoids contention on the shared browser.

Artifact	Path
Evidence brief (fleet input)	data/evidence-brief.md
App source (as served)	data/regions-map.html
Region registry	data/regions_index.js
Lighthouse report	data/lighthouse/report.{json,html}
Fleet reports ×5	data/fleet/*.md
Screenshots ×9 (full-res PNG)	screenshots/

Caveats: single-location measurement (UK edge, datacentre bandwidth — consumer 4G will be slower than the 19 s observed for full load); Lighthouse performance category not run (canvas-heavy SPA — Resource Timing used instead); the unrelated browser tab present in the shared sidecar was left untouched; no write/mutation testing was performed against the live site.